Project Proposal - ClinicBook: Secure Clinic Booking System

Course: Application Security
Student: Juan Felipe Montero Cortes
Date: April 2026

A. Scope (Problem)

Many small clinics still rely on phone calls or paper-based systems to manage appointments, leading to scheduling conflicts, lost patient records, and no access control over sensitive health information. There is no structured way for patients to find available doctors, book appointments, or share medical documents securely.

Who the users are:

- **Patients** - individuals looking to book appointments and share documents with their doctor.
- **Doctors** - healthcare providers who need to manage their schedule and review patient documents.
- **Admins** - clinic staff who oversee user accounts and monitor system activity.

What the app will do:

- Allow patients to register, search for doctors by name or specialty, and book appointments.
- Allow patients to upload medical documents (referrals, test results) linked to an appointment.
- Allow doctors to view their appointments and access uploaded patient documents.
- Allow admins to approve doctor registrations, view all appointments, and review an audit log.

What will NOT be included (boundaries):

- Online payments or billing.
- Email or SMS notifications.
- Video consultations.
- Mobile native app (web browser only).

B. Objectives (Solution)

ClinicBook resolves the problem by providing a role-based web application with a clear client-server architecture and realistic security controls.

Main Features:

1. Patient self-registration and login
2. Doctor search by name and specialty
3. Appointment booking and status management
4. Secure medical document upload (PDF, PNG, JPG - max 2 MB)
5. Role-based dashboards for patient, doctor, and admin
6. Admin panel: doctor approval workflow + audit log viewer

Key Security Features:

- **Authentication:** Password hashing with bcrypt; session-based login with session regeneration on sign-in to prevent session fixation.
- **Authorization:** Role-based middleware (patient, doctor, admin) and per-resource ownership checks (a patient cannot access another patient's documents).
- **Input Validation:** All form inputs and query parameters are validated server-side using express-validator.
- **SQL Injection Prevention:** Exclusively parameterized queries via better-sqlite3 prepared statements.
- **File Upload Security:** MIME type and file extension whitelist, 2 MB size limit, UUID-based stored filenames, files stored outside the web root.
- **Rate Limiting:** Login and registration endpoints are limited to 10 requests per IP per 5 minutes.
- **Security Headers:** helmet middleware sets CSP, X-Frame-Options, HSTS, and other protective headers.
- **Audit Logging:** All sensitive actions (login, logout, file upload, appointment booking, admin actions) are recorded in a database audit_logs table with timestamp, IP address, and user agent.

Minimum Required Modules:

- Login / Registration forms
- Doctor search form
- File upload form
- REST API endpoints for all core actions
- Admin panel with role-based access